

Module 6: Cybersecurity Fundamentals



Training structure



EASY



SIMULATION

Part 1: Introduction to Cybersecurity



Welcome to Cybersecurity Fundamentals

- **The largest and most important module**
 - 50 hours of content
 - Offense AND defense perspectives
 - Hands-on tools and techniques
 - Real-world attack analysis
- **This is where it all comes together**

Module 6 Overview

- **What we'll cover:**
 - Threat landscape and attack frameworks
 - Intelligence gathering (OSINT)
 - Vulnerability analysis
 - Phishing and social engineering
 - Password attacks
 - Network traffic analysis
 - Malware analysis basics
 - SIEM and detection

Why Study Offensive Security?

- **"To defeat your enemy, you must know your enemy"**
 - Understanding attacks enables better defense
 - Penetration testers find vulnerabilities first
 - Incident responders must understand attacker TTPs
 - Security engineers build defenses against real attacks
- **Know the attack → Build the defense**

The Security Mindset

- **Attacker thinks:**
 - "What's exposed?"
 - "Where's the weakness?"
 - "How do I stay hidden?"
 - "What's valuable?"
- **Defender thinks:**
 - "What's my attack surface?"
 - "What would I target?"
 - "How would I detect this?"
 - "What's my response?"

What is a Cyber Threat?

- **Threat:** Any potential danger to information or systems
- **Components:**
 - **Threat Actor:** Who (hacker, nation-state, insider)
 - **Capability:** What they can do (skills, tools)
 - **Intent:** Why (money, espionage, disruption)
 - **Opportunity:** When/where (vulnerabilities, access)

Threat Actors - Who Attacks?

- **Threat Actor Categories:**
 1. **Script Kiddies** - Low skill, use others' tools
 2. **Hacktivists** - Politically motivated
 3. **Cybercriminals** - Financially motivated
 4. **Insiders** - Employees, contractors
 5. **Nation-States** - Government-sponsored
 6. **APTs** - Advanced Persistent Threats

Script Kiddies

- **Characteristics:**
 - Little technical understanding
 - Use pre-built tools and scripts
 - Motivated by curiosity or bragging rights
 - Easily deterred by basic security
- **Danger level:** Low individually, but numerous

Hacktivists

- **Characteristics:**
 - Politically or socially motivated
 - Target organizations they oppose
 - Focus on embarrassment and disruption
 - May leak data or deface websites
- **Examples:** Anonymous, LulzSec

Cybercriminals

- **Characteristics:**
 - Financially motivated
 - Well-organized (RaaS - Ransomware as a Service)
 - Target anyone with money or valuable data
 - Professional operations with "customer service"
- **Examples:** LockBit, BlackCat/ALPHV, Conti

Insider Threats

- **Types:**
 - **Malicious:** Intentional harm (revenge, profit)
 - **Negligent:** Careless mistakes
 - **Compromised:** Account stolen by external attacker
- **Why dangerous:**
 - Already have legitimate access
 - Know where valuable data is
 - Trusted by systems and people

Nation-State Actors

- **Major cyber powers:**
 - US USA (NSA, Cyber Command)
 - RU Russia (FSB, GRU, SVR)
 - CN China (PLA Unit 61398, MSS)
 - KP North Korea (Lazarus Group)
 - IR Iran (APT33, APT34)
- **Motivations:** Espionage, sabotage, influence operations

Advanced Persistent Threats (APTs)

- **APT Characteristics:**
 - **Advanced:** Sophisticated techniques and tools
 - **Persistent:** Remain hidden for months/years
 - **Threat:** Clear intent to cause harm
- **Tactics:**
 - Custom malware
 - Zero-day exploits
 - Supply chain attacks
 - Long-term reconnaissance

Threat Motivations

Motivation	Actor Type	Target
Financial	Criminals	Anyone with money
Espionage	Nation-states	Government, defense, IP
Ideology	Hacktivists	Controversial organizations
Revenge	Insiders	Former employers
Curiosity	Script kiddies	Easy targets

The Threat-Vulnerability-Risk Triangle

- **Core Security Concepts:**
 - **Threat × Vulnerability = Risk**
 - **Threat:** Potential danger (attacker, malware)
 - **Vulnerability:** Weakness that can be exploited
 - **Risk:** Likelihood and impact of exploitation
 - **No vulnerability → No risk (even with threat)**

Understanding Vulnerabilities

- **Vulnerability Categories:**
 - **Software bugs:** Coding errors (buffer overflow)
 - **Misconfigurations:** Incorrect settings
 - **Design flaws:** Architecture problems
 - **Human factors:** Social engineering targets
 - **Zero-days:** Unknown vulnerabilities
 - **CVE:** Common Vulnerabilities and Exposures database

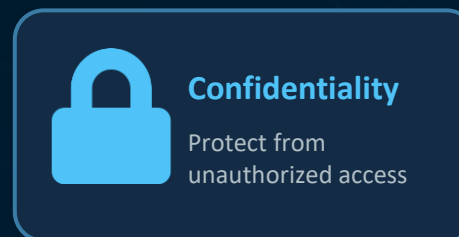
Risk Assessment Basics

Low Impact	High Impact
High Likelihood	Medium Risk
Low Likelihood	Low Risk

The CIA Triad

- **Three pillars of information security:**
 - **Confidentiality:** Only authorized users can access data
 - Encryption, access controls, authentication
 - **Integrity:** Data is accurate and unaltered
 - Hashing, digital signatures, checksums
 - **Availability:** Systems and data accessible when needed
 - Redundancy, backups, DDoS protection
 - **Every attack targets at least one pillar**

The Foundation of Information Security

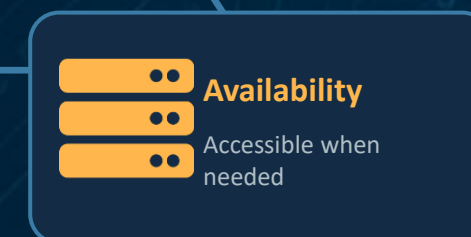


Security Controls

- C** Encryption, access controls, MFA, classification
- I** Hashing, digital signatures, checksums, audit logs
- A** Redundancy, backups, load balancing, DDoS protection

Attack Examples

- C** Data breach, eavesdropping, credential theft
- I** Man-in-the-middle, SQL injection, log tampering
- A** DDoS, ransomware, wiper malware



Every security control protects at least one pillar | Every attack targets at least one pillar

כל הזכויות שמורות לסייברלאבס טכנולוגיות בע"מ

Compliance and Regulatory Requirements

- **Common Frameworks:**
 - **PCI-DSS:** Payment card data
 - **HIPAA:** Healthcare information
 - **GDPR:** EU personal data
 - **SOX:** Financial reporting
 - **ISO 27001:** Information security management
- **Compliance $\neq$ Security (but helps)**

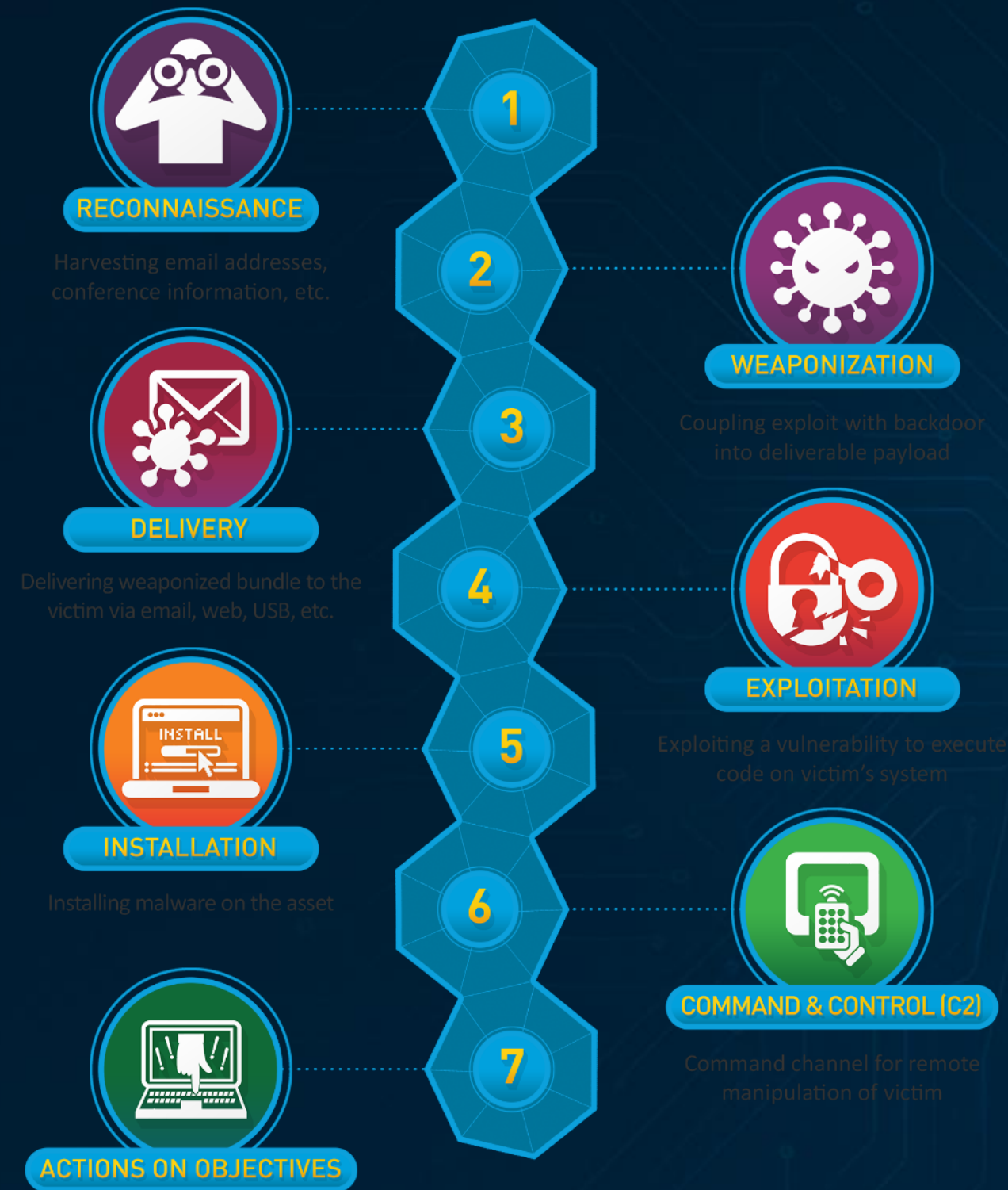
Why Attack Frameworks Matter

- **Frameworks provide:**
 - Common language for security professionals
 - Structure for understanding attacks
 - Guidance for building defenses
 - Metrics for measuring security
- **Key frameworks:**
 - Cyber Kill Chain (Lockheed Martin)
 - MITRE ATT&CK
 - Diamond Model

The Cyber Kill Chain

- **Lockheed Martin Cyber Kill Chain:**
 - 1.Reconnaissance** - Research target
 - 2.Weaponization** - Create attack payload
 - 3.Delivery** - Transmit payload to target
 - 4.Exploitation** - Trigger vulnerability
 - 5.Installation** - Install persistence
 - 6.Command & Control** - Establish communication
 - 7.Actions on Objectives** - Achieve goals

The Cyber Kill Chain



כל הזכויות שמורות לסייברלאבס טכנולוגיות בע"מ

Kill Chain - Reconnaissance

- **Attacker activities:**
 - Search public information (OSINT)
 - Identify employees (LinkedIn)
 - Map network infrastructure
 - Find email addresses
 - Discover technologies used
- **Defender opportunities:**
 - Monitor for scanning
 - Limit public information
 - Honeypots for detection

Kill Chain - Weaponization

- **Attacker activities:**
 - Select or create malware
 - Package exploit with payload
 - Test against defenses
 - Prepare delivery mechanism
- **Defender opportunities:**
 - Threat intelligence
 - Understanding attacker TTPs
 - (Limited direct detection)

Kill Chain - Delivery

- **Common delivery methods:**
 - Phishing emails (most common)
 - Malicious websites (watering hole)
 - USB drives
 - Compromised software updates
 - Direct exploitation
- **Defender opportunities:**
 - Email filtering
 - Web proxies
 - User awareness training
 - Network monitoring

Kill Chain - Exploitation

- **Attacker activities:**
 - Exploit software vulnerability
 - Abuse application feature
 - Social engineering success
 - Credential theft
- **Defender opportunities:**
 - Patch management
 - Application whitelisting
 - Endpoint protection
 - Least privilege

Kill Chain - Installation

- **Attacker activities:**
 - Install backdoor
 - Create persistence (scheduled tasks, services)
 - Establish redundant access
 - Cover tracks
- **Defender opportunities:**
 - Endpoint detection
 - Baseline monitoring
 - Registry/file integrity monitoring
 - Behavioral analysis



CYBERLABS Kill Chain - Command & Control (C2)

- **Attacker activities:**
 - Establish outbound connection
 - Use encrypted channels (HTTPS)
 - Blend with normal traffic
 - Maintain reliable communication
- **Defender opportunities:**
 - Network monitoring
 - DNS analysis
 - Proxy logs
 - Behavioral analytics

Kill Chain - Actions on Objectives

- **Attacker goals:**
 - Data theft (exfiltration)
 - Ransomware deployment
 - Espionage (long-term access)
 - Destruction (wiper malware)
 - Lateral movement (expand access)
- **Defender opportunities:**
 - Data loss prevention
 - Encryption detection
 - Behavior monitoring
 - Incident response

Breaking the Kill Chain

- **Defense in Depth:**
 - Multiple controls at each stage
 - If one fails, another catches
 - Earlier detection = less damage
- **Goal:** Break the chain before Actions on Objectives

MITRE ATT&CK Introduction

- **ATT&CK = Adversarial Tactics, Techniques, and Common Knowledge**
- **What it provides:**
 - Comprehensive knowledge base of attacker behavior
 - Standardized taxonomy
 - Real-world observations (not theoretical)
 - Maps techniques to detection and mitigation
- **Website: attack.mitre.org**

ATT&CK Structure

- **Hierarchy:**
 - **Tactics:** The "why" (attacker goals)
 - **Techniques:** The "how" (methods used)
 - **Sub-techniques:** Specific variations
 - **Procedures:** Real-world examples
 - **14 Enterprise Tactics covering full attack lifecycle**

ATT&CK Tactics Overview

- **Enterprise Tactics:**
 1. Reconnaissance
 - 1.Resource Development
 - 2.Initial Access
 - 3.Execution
 - 4.Persistence
 - 5.Privilege Escalation
 - 6.Defense Evasion
 - 7.Credential Access
 - 8.Discovery
 - 9.Lateral Movement
 - 10.Collection
 - 11.Command and Control
 - 12.Exfiltration
 - 13.Impact

Tactic - Reconnaissance (TA0043)

- **Goal:** Gather information for targeting
- **Techniques include:**
 - T1595: Active Scanning
 - T1592: Gather Victim Host Information
 - T1589: Gather Victim Identity Information
 - T1591: Gather Victim Org Information
 - T1593: Search Open Websites/Domains

Tactic - Initial Access (TA0001)

- **Goal:** Get into the network
- **Techniques include:**
 - T1566: Phishing
 - T1190: Exploit Public-Facing Application
 - T1133: External Remote Services
 - T1078: Valid Accounts
 - T1195: Supply Chain Compromise

Tactic - Persistence (TA0003)

- **Goal:** Maintain access across restarts
- **Techniques include:**
 - T1547: Boot or Logon Autostart Execution
 - T1053: Scheduled Task/Job
 - T1136: Create Account
 - T1505: Server Software Component
 - T1098: Account Manipulation

Tactic - Privilege Escalation (TA0004)

- **Goal:** Get higher-level permissions
- **Techniques include:**
 - T1068: Exploitation for Privilege Escalation
 - T1548: Abuse Elevation Control Mechanism
 - T1134: Access Token Manipulation
 - T1484: Domain Policy Modification

Tactic - Defense Evasion (TA0005)

- **Goal:** Avoid detection
- **Techniques include:**
 - T1070: Indicator Removal on Host
 - T1036: Masquerading
 - T1027: Obfuscated Files
 - T1562: Impair Defenses
 - T1218: Signed Binary Proxy Execution

Tactic - Credential Access (TA0006)

- **Goal:** Steal account credentials
- **Techniques include:**
 - T1003: OS Credential Dumping
 - T1558: Steal or Forge Kerberos Tickets
 - T1110: Brute Force
 - T1556: Modify Authentication Process
 - T1552: Unsecured Credentials

Tactic - Lateral Movement (TA0008)

- **Goal:** Move through the network
- **Techniques include:**
 - T1021: Remote Services
 - T1570: Lateral Tool Transfer
 - T1563: Remote Service Session Hijacking
 - T1550: Use Alternate Authentication Material

Tactic - Exfiltration (TA0010)

- **Goal:** Steal data from the network
- **Techniques include:**
 - T1041: Exfiltration Over C2 Channel
 - T1048: Exfiltration Over Alternative Protocol
 - T1567: Exfiltration Over Web Service
 - T1052: Exfiltration Over Physical Medium

Using ATT&CK for Defense

- **Practical applications:**
 - **Gap analysis:** What techniques can't we detect?
 - **Detection engineering:** Build detections per technique
 - **Threat intelligence:** Map threats to techniques
 - **Red teaming:** Structure testing around ATT&CK
 - **Vendor evaluation:** Does this tool cover ATT&CK?

ATT&CK Navigator

- **ATT&CK Navigator Tool:**
 - Visual matrix interface
 - Color-code coverage
 - Layer multiple analyses
 - Export and share
- **Uses:**
 - Map detection coverage
 - Show threat actor techniques
 - Identify defensive gaps
- **URL:** mitre-attack.github.io/attack-navigator/

ATT&CK Navigator

Software Execution x								
selection controls layer controls technique controls								
Initial Access 9 techniques	Execution 10 techniques	Persistence 18 techniques	Privilege Escalation 12 techniques	Defense Evasion 37 techniques	Credential Access 14 techniques	Discovery 25 techniques	Lateral Movement 9 techniques	Collection 17 techniques
Replication Through Removable Media Drive-by Compromise Valid Accounts (2/4) Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (2/3) Supply Chain Compromise (1/3) Trusted Relationship	Native API Windows Management Instrumentation Command and Scripting Interpreter (7/8) Exploitation for Client Execution Shared Modules Scheduled Task/Job (3/6) Software Deployment Tools Inter-Process Communication (2/2) System Services (2/2) User Execution (2/2)	BITS Jobs Hijack Execution Flow (7/11) Traffic Signaling (0/1) Valid Accounts (2/4) Account Manipulation (1/4) Browser Extensions Boot or Logon Autostart Execution (8/12) Compromise Client Software Binary External Remote Services Scheduled Task/Job (3/6) Boot or Logon Initialization Scripts (3/5) Create Account (2/3) Create or Modify System Process (4/4) Event Triggered Execution (10/15) Implant Container Image	Process Injection (8/11) Access Token Manipulation (5/5) Exploitation for Privilege Escalation Hijack Execution Flow (7/11) Valid Accounts (2/4) Boot or Logon Autostart Execution (8/12) Group Policy Modification Scheduled Task/Job (3/6) Abuse Elevation Control Mechanism (4/4) Boot or Logon Initialization Scripts (3/5) Create or Modify System Process (4/4) Event Triggered Execution (10/15)	Obfuscated Files or Information (5/5) Deobfuscate/Decode Files or Information Modify Registry Process Injection (8/11) Rootkit Indicator Removal on Host (5/6) Access Token Manipulation (5/5) Virtualization/Sandbox Evasion (3/3) BITS Jobs Hijack Execution Flow (7/11) Masquerading (5/6) Traffic Signaling (0/1) Valid Accounts (2/4) Indirect Command Execution Group Policy Modification Rogue Domain Controller XSL Script Processing Abuse Elevation Control Mechanism (4/4)	Credentials from Password Stores (3/3) Network Sniffing OS Credential Dumping (8/8) Brute Force (3/4) Steal Web Session Cookie Two-Factor Authentication Interception Unsecured Credentials (4/6) Exploitation for Credential Access Forced Authentication Input Capture (3/4) Man-in-the-Middle (1/2) Modify Authentication Process (3/4) Steal Application Access Token Steal or Forge Kerberos Tickets (3/4)	System Information Discovery File and Directory Discovery Process Discovery System Network Configuration Discovery System Owner/User Discovery Query Registry System Network Connections Discovery System Time Discovery System Service Discovery Peripheral Device Discovery Remote System Discovery Application Window Discovery Network Service Scanning Network Share Discovery Software Discovery (1/1) Network Sniffing	Replication Through Removable Media Lateral Tool Transfer Exploitation of Remote Services Taint Shared Content Remote Services (6/6) Software Deployment Tools Internal Spearphishing Remote Service Session Hijacking (1/2) Use Alternate Authentication Material (2/4)	Screen Capture Data from Local System Audio Capture Archive Collected Data (3/3) Clipboard Data Video Capture Automated Collection Data from Removable Media Man in the Browser Data from Network Shared Drive Data from Cloud Storage Object Data from Configuration Repository (0/2) Data from Information Repositories (1/2) Data Staged (1/2) Email Collection (2/3) Input Capture (3/4)

כל הזכויות שמורות לסייבר לאבס טכנולוגיות בע"מ

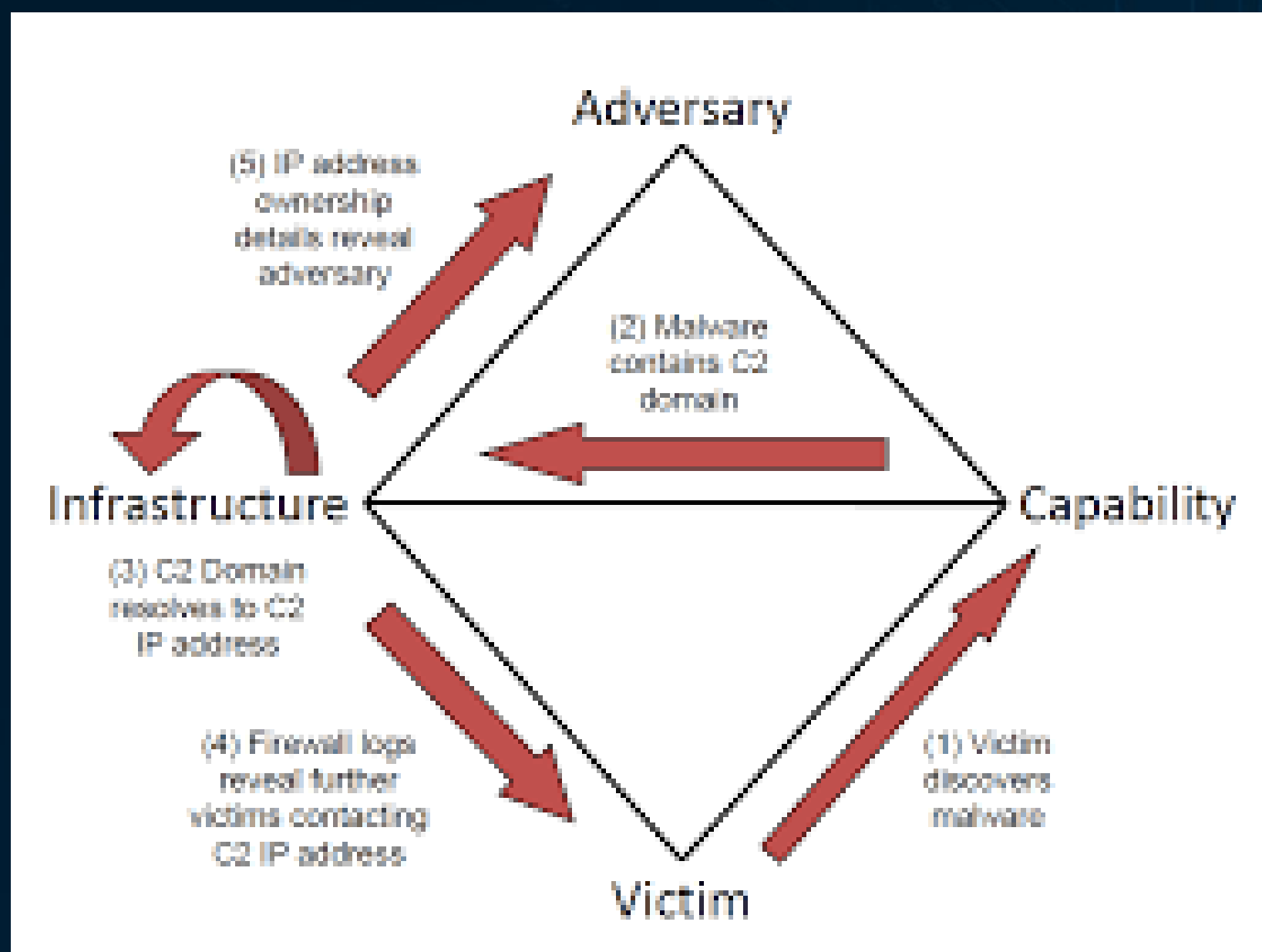
ATT&CK Example - APT29

- **APT29 (Cozy Bear) - Russia**
 - Initial Access: Spearphishing, Valid Accounts
 - Execution: PowerShell, Windows Management
 - Persistence: Registry Run Keys, Scheduled Tasks
 - Defense Evasion: Obfuscation, Timestomp
 - C2: Web Protocols, Encrypted Channel

Diamond Model Overview

- **Four core features:**
 - **Adversary:** Who is attacking
 - **Capability:** Tools and techniques used
 - **Infrastructure:** Systems used in attack
 - **Victim:** Target of attack
- **Relationships connect all elements**

Diamond Model Overview



Comparing Frameworks

Framework	Strength	Best Use
Kill Chain	Linear progression	Understanding attack flow
ATT&CK	Comprehensive detail	Detection and defense
Diamond	Relationship analysis	Threat intelligence

Section 1-2 Summary

- **Key takeaways:**
 - Threats range from script kiddies to nation-states
 - Risk = Threat × Vulnerability
 - Kill Chain shows attack stages
 - ATT&CK provides comprehensive technique taxonomy
 - Multiple frameworks together provide complete picture
 - **Next:** Intelligence gathering (OSINT)

Turning data into actionable knowledge

Threat Intelligence



What is Threat Intelligence?

- **Threat Intelligence (TI):** Knowledge about threats that enables informed security decisions
- **Strategic TI:** High-level — for executives. Geopolitical trends, threat actor campaigns
- **Operational TI:** Campaigns in progress — for incident responders and SOC managers
- **Tactical TI:** IOCs, TTPs — for analysts and SIEM rules. Actionable immediately
- **Key insight:** TTPs are more valuable than IOCs — IPs and hashes go stale in days, TTPs persist for years

The Intelligence Lifecycle

- **Direction:** Define requirements — what do we need to know?
- **Collection:** Gather raw data from feeds, dark web, OSINT, internal telemetry
- **Processing:** Normalize and correlate — parse logs, deduplicate, enrich
- **Analysis:** Apply context — is this relevant? What does it mean?
- **Dissemination:** Share findings — SIEM rules, block lists, executive reports
- **Feedback:** Did the intelligence help? Refine requirements and repeat

Indicators of Compromise (IOCs)

- **IOC:** Observable artifact that indicates a system may be compromised
- **File-based:** MD5/SHA1/SHA256 hashes of malicious files
- **Network-based:** Malicious IP addresses, domains, URLs, SSL certificate hashes
- **Host-based:** Registry keys, file paths, mutex names, process names
- **Behavioral:** Sequences of actions — more stable than atomic IOCs
- **Email-based:** Sender addresses, subject lines, attachment names
- **Formats:** STIX, OpenIOC, YARA rules, Snort/Suricata signatures

Pyramid of Pain

- **Concept:** David Bianco's model — higher = more painful for attacker to change
- **Hash Values (Trivial):** Easy for attacker — recompile malware, hash changes instantly
- **IP Addresses (Easy):** Attacker uses bulletproof hosting, Tor, cloud IPs — easy to rotate
- **Domain Names (Simple):** Slightly harder — domain registration takes effort but still fast
- **Network Artifacts (Annoying):** User-agent strings, URI patterns — requires tool modification
- **Host Artifacts (Annoying):** Registry keys, file paths — requires malware rewrite
- **TTPs (Tough!):** Changing attack methodology is expensive — forces adversary to retrain
- **Defender goal:** Build detections at TTP level — use ATT&CK techniques

STIX & TAXII — Sharing Threat Intelligence

- **STIX:** Structured Threat Information Expression — JSON format for describing threats
- **STIX objects include:** Indicators, Malware, Threat Actor, Attack Pattern, Campaign, COA
- **TAXII:** Trusted Automated Exchange of Intelligence Information — transport protocol
- **TAXII uses:** REST API over HTTPS to push/pull STIX bundles between organizations
- **Why it matters:** Enables automated sharing — block a new IOC across 1000 organizations in minutes
- **Examples:** MISP, OpenCTI, Anomali, EclecticIQ all speak STIX/TAXII

Threat Intelligence Platforms & Feeds

- **Free feeds:** AlienVault OTX (otx.alienvault.com), abuse.ch, Emerging Threats
- **VirusTotal:** Hash, IP, domain, URL reputation — backed by 70+ AV engines
- **MISP:** Open-source TI platform — share IOCs within your organization or community
- **ISACs:** Information Sharing and Analysis Centers — sector-specific (FS-ISAC, H-ISAC)
- **Commercial:** Recorded Future, Mandiant, CrowdStrike Intel, Microsoft MSTIC
- **In the lab:** We will use VirusTotal to analyze file hashes and network IOCs
- **In the lab:** We will use MITRE ATT&CK to map threat actor TTPs

What is OSINT?

- **Open Source Intelligence:**
 - Information gathered from publicly available sources
- **Sources include:**
 - Websites and social media
 - Public records and databases
 - News and publications
 - Technical data (DNS, certificates)
 - Search engines

OSINT for Attackers vs Defenders

- **Attackers use OSINT to:**
 - Find targets and employees
 - Discover technologies used
 - Identify vulnerabilities
 - Plan social engineering
- **Defenders use OSINT to:**
 - Understand attack surface
 - Monitor for threats
 - Investigate incidents
 - Gather threat intelligence

Google Dorking

- **Google search operators:**

<code>site:example.com</code>	- Search specific site
<code>filetype:pdf</code>	- Find specific file types
<code>intitle:"index of"</code>	- Find directory listings
<code>inurl:admin</code>	- URLs containing string
<code>"password" filetype:xlsx</code>	- Find exposed credentials

- **Powerful for finding exposed information**

Google Dorking Examples

- **Common dorks for security:**

```
site:company.com filetype:pdf confidential  
site:company.com "internal use only"  
site:company.com inurl:admin  
site:company.com filetype:sql  
intitle:"index of" site:company.com
```

- **Google Hacking Database (GHDB):** Curated dorks collection

WHOIS Lookups

- **WHOIS provides:**
 - Domain registration information
 - Registrant contact details
 - Registration dates
 - Name servers
 - (Often privacy-protected now)
- **Tools:** whois command, online lookup sites

DNS Reconnaissance

- **DNS records reveal infrastructure:**
 - **A/AAAA:** IP addresses
 - **MX:** Email servers
 - **TXT:** SPF, DKIM, verification records
 - **NS:** Name servers
 - **CNAME:** Aliases
 - **Tools:** nslookup, dig, host, dnsenum

Certificate Transparency

- **Certificate Transparency (CT):**
 - Public log of all SSL/TLS certificates
 - Reveals subdomains and infrastructure
 - Historical certificate data
- **Tools:**
 - crt.sh
 - Censys
 - Google Certificate Transparency

crt.sh Demonstration

- **Using crt.sh:**
 1. Go to crt.sh
 2. Search: `%.example.com`
 3. Review all issued certificates
 4. Find subdomains: `dev.example.com`, `staging.example.com`, etc.
- **Discovers:**
 - Development environments
 - Internal systems
 - Forgotten infrastructure



CYBERLABS Shodan - The Search Engine for IoT

- **Shodan indexes:**
 - Internet-connected devices
 - Open ports and services
 - Banners and versions
 - Vulnerabilities
 - Screenshots
- **"The search engine for hackers"**

Shodan Search Examples

- Useful Shodan queries:

<code>org:"Company Name"</code>	- Organization's assets
<code>hostname:example.com</code>	- Specific domain
<code>port:3389</code>	- RDP servers
<code>product:"Apache"</code>	- Specific software
<code>vuln:CVE-2021-44228</code>	- Vulnerable systems
<code>country:US</code>	- Geographic filter

Social Media Intelligence

- **Social media reveals:**
 - Employee names and roles
 - Technologies used (job postings)
 - Organizational structure
 - Personal information (social engineering)
 - Company culture and events
- **Primary platforms:** LinkedIn, Twitter, Facebook

LinkedIn Reconnaissance

- **LinkedIn provides:**
 - Employee list and org chart
 - Email format (john.smith@company.com)
 - Technologies from job requirements
 - Contractors and vendors
 - Career history (former employees)
 - For attackers:** Target identification, social engineering
- **For defenders:** Understand exposed information

Email OSINT

- **Discovering email addresses:**
 - LinkedIn profiles
 - Website contact pages
 - Document metadata
 - Hunter.io, Clearbit
 - Google: "@company.com"
- **Verify emails:** Email verification services

Document Metadata Analysis

- **Documents contain hidden data:**
 - Author name and email
 - Software versions
 - Computer names
 - File paths
 - GPS coordinates (images)
- **Tool:** exiftool, FOCA

Passive vs Active Reconnaissance

Passive	Active
No direct contact	Touches target systems
OSINT, public data	Scanning, probing
Undetectable	May trigger alerts
Legal always	Legal with permission

OSINT Tools Summary

Tool	Purpose
Google Dorks	Find exposed information
WHOIS	Domain registration
crt.sh	Certificate transparency
Shodan	Internet-connected devices
theHarvester	Aggregate OSINT sources
Maltego	Visual link analysis
recon-ng	OSINT framework

Part 1 Summary

- **Part 1 covered:**
 - Threat actors from script kiddies to APTs
 - Threat-Vulnerability-Risk relationship
 - Cyber Kill Chain attack stages
 - MITRE ATT&CK framework and tactics
 - OSINT techniques and tools
- **Next in Part 2:**
 - URL and domain analysis
 - Vulnerability scanning
 - Exploitation concepts

Thank you